

Assignment 7: Security Review

Personal Productivity AI Agent

AI Engineering Fellowship 2026 – Week 3 Student:
Hassan Murtaza Zaidi

Security Overview

This review summarizes the primary security risks and the controls implemented or recommended for the Personal Productivity AI Agent.

API Key Protection

Store API keys in environment variables (.env), never commit secrets to GitHub.

Prompt Injection

Treat user input as untrusted, restrict tool execution through explicit routing and validation.

Tool Permission Boundaries

Require human approval before destructive operations such as update, complete, and delete.

Sensitive Data Exposure

Avoid logging secrets or personal information. Sanitize logs before storage.

Destructive Actions

Require explicit confirmation before write/delete actions.

Database Access

Restrict access to application code only and validate all IDs before operations.

User Input Validation

Validate data types and required fields before tool execution.

Rate Limiting

Limit repeated requests to reduce abuse and accidental loops.

Approval Bypass Risks

Enforce approval checks in both controller and tool execution layers.

Log Privacy

Store only operational logs needed for debugging; exclude credentials.

Conclusion

Applying layered validation, approval gates, secure secret management, and careful logging significantly reduces operational and security risks for the agent.